Attacker | Target | Monitoring | Admin host

BILICHECK: HARDENING DAN MONITORING TARGET NODE

PBL Kelompok 12 | TEK1314 Keamanan Siber
Checkpoint Minggu ke-9



Dinda Kahrnita | J0404241003
Lead



Ahmad Jawawi | J0404241089
Blue Team



Radithya Hafizh K | J0404241160
Blue Team



Daffa' Raihandi | J0404241038
Red Team

KONTEKS: BILICHECK, IOT PENGUKUR BILIRUBIN

ESP32 + sensor → MQTT broker → Firebase → Aplikasi Flutter

Cara Kerja :

- Dua modalitas (fotodioda dan LDR)
- Konsentrasi dihitung dari absorbansi cahaya (mirip hukum Beer-Lambert)
- ESP32 mengirim JSON (nilai mentah, jaundice_percentage, concentration)

Ruang Lingkup PBL :

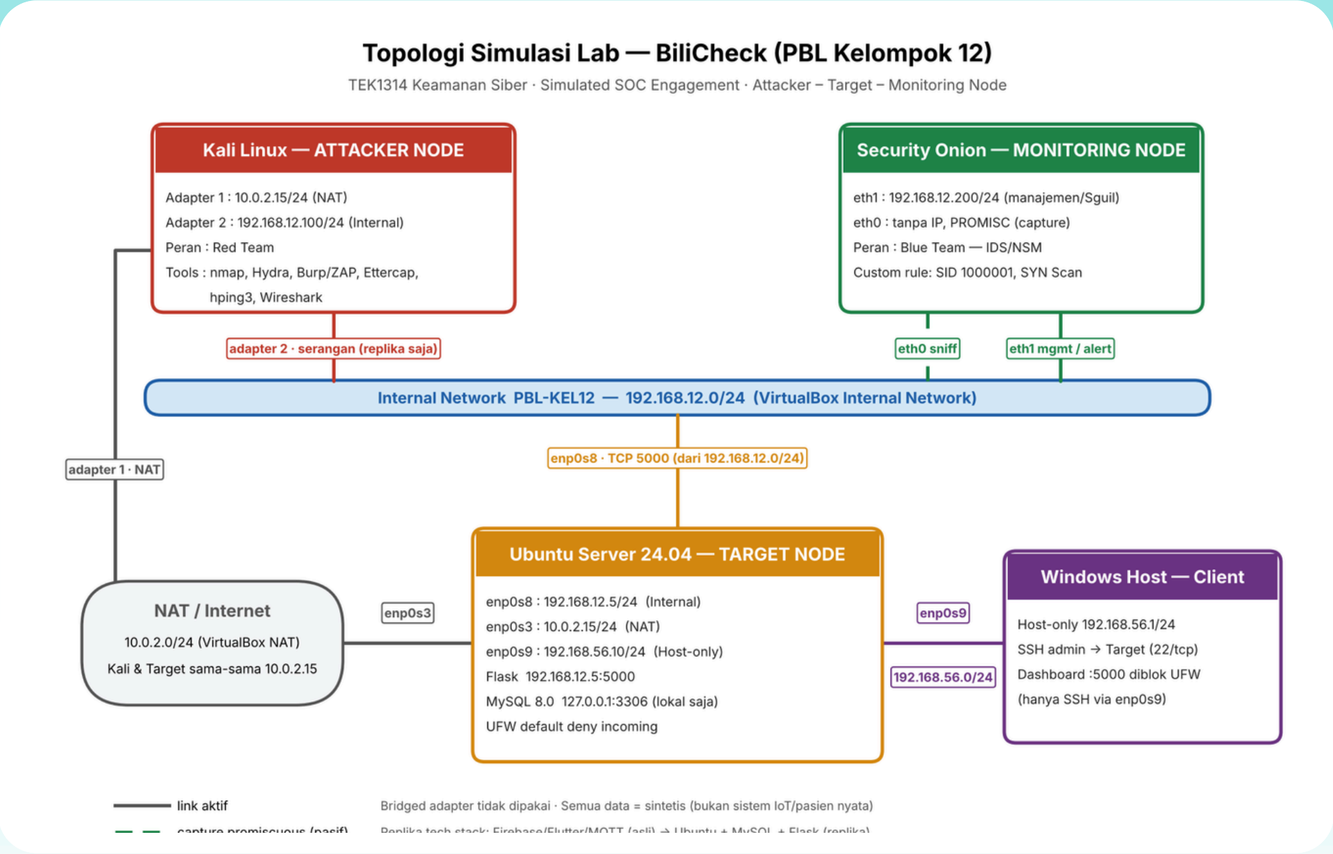
- Replika terbatas di VM Lab
- Fokus ke hardening server, kontrol akses, monitoring jaringan
- Sensor fisik dan integrasi Firebase lengkap belum direplikasi

TECH STACK ASLI KE REPLIKA TARGET NODE

Komponen	Proyek IoT asli	Replika di VM lab
OS backend	Firebase (cloud terkelola; OS tidak dikelola tim)	Ubuntu Server 24.04.5 LTS
Database	Firebase Realtime DB + Cloud Firestore	MySQL 8.0.46
Protokol sensor	MQTT (test.mosquitto.org:1883)	Belum direplikasi; dashboard diakses via HTTP, TCP 5000
Dashboard	Aplikasi klien Flutter (Dart)	Dashboard Flask + Security Onion (monitoring)

- Firebase adalah layanan cloud, bukan OS. Flutter adalah framework dan Dart bahasanya, keduanya bukan backend
- MySQL pada replika adalah pengganti simulasi lokal, bukan integrasi Firebase sesungguhnya
- Semua data (users, pasien_bayi, pengukuran) adalah data sintetis, tidak untuk keputusan medis

ARSITEKTUR SIMULASI LAB



Kali Linux (Attacker)
192.168.12.100

Ubuntu Server (Target)
192.168.12.5 | 192.168.56.10

Security Onion (Monitoring)
192.168.12.200

Windows host (Admin)
192.168.56.1

Internal 192.168.12.0/24 | Host-only 192.168.56.0/24 | NAT untuk update paket. Bridged tidak dipakai.

PROGRES HARDENING: 11 SELESAI, 6 TERSISA

11/17

kontrol selesai dan punya bukti before/after

A Access dan autentikasi 2/4

B Service dan attack surface 6/8

C Data dan aplikasi 3/5

SEBELUM: 2 port terbuka (22, 5000)

```
┌──(root㉿kali)-[~]
└─# sudo nmap -sS -p- -n -Pn --min-rate 2000 -v 192.168.12.5 -oN nmap-sebelum
.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-20 01:16 -0400
Initiating ARP Ping Scan at 01:16
Scanning 192.168.12.5 [1 port]
Completed ARP Ping Scan at 01:16, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 01:16
Scanning 192.168.12.5 [65535 ports]
Discovered open port 22/tcp on 192.168.12.5
SYN Stealth Scan Timing: About 46.58% done; ETC: 01:17 (0:00:36 remaining)
Discovered open port 5000/tcp on 192.168.12.5
Completed SYN Stealth Scan at 01:17, 65.74s elapsed (65535 total ports)
Nmap scan report for 192.168.12.5
Host is up (0.00042s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT     STATE SERVICE
22/tcp   open  ssh
5000/tcp open  upnp
MAC Address: 08:00:27:C5:69:9F (Oracle VirtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 65.88 seconds
           Raw packets sent: 131120 (5.769MB) | Rcvd: 54 (2.360KB)
```

nmap -sS -p- dari Kali ke 192.168.12.5

SESUDAH: 1 port terbuka (5000)

```
┌──(root㉿kali)-[~]
└─# sudo nmap -sS -p- -n -Pn --min-rate 2000 -v 192.168.12.5 -oN nmap-sesudah
.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-20 01:18 -0400
Initiating ARP Ping Scan at 01:18
Scanning 192.168.12.5 [1 port]
Completed ARP Ping Scan at 01:18, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 01:18
Scanning 192.168.12.5 [65535 ports]
SYN Stealth Scan Timing: About 46.85% done; ETC: 01:19 (0:00:35 remaining)
Discovered open port 5000/tcp on 192.168.12.5
Completed SYN Stealth Scan at 01:19, 65.69s elapsed (65535 total ports)
Nmap scan report for 192.168.12.5
Host is up (0.00052s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT     STATE SERVICE
5000/tcp open  upnp
MAC Address: 08:00:27:C5:69:9F (Oracle VirtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 65.86 seconds
           Raw packets sent: 131087 (5.768MB) | Rcvd: 19 (820B)
```

Sudah

- Root SSH ditolak, MaxAuthTries 3
- UFW deny; SSH hanya host-only
- Flask dan MySQL tidak terbuka
- User DB SELECT-only

Belum (target Minggu 11)

- A3 Password auth SSH
- A4 fail2ban
- B7 Patch OS
- B8 Akun default
- C4 Validasi input
- C5 Logging

LIVE DEMO: SECURITY ONION MEMANTAU TRAFFIC LAB

1 Ping dari Kali

```
ping -c 4 192.168.12.5
```

Alert yang diharapkan

- PBL - ICMP Traffic Detected (SID 1000001)
- GPL ICMP_INFO PING

2 Nmap dari Kali

```
sudo nmap -sS 192.168.12.5
```

Alert yang diharapkan

- PBL TEST - SYN Scan Detected
- ET SCAN Suspicious inbound

3 Lihat alert di Sguil

```
Security Onion
192.168.12.200
```

Alert yang diharapkan

- Alert muncul di konsol analyst
- Interface capture eth0 (PROMISC)

Traffic dummy cukup di tahap ini; belum perlu serangan sungguhan.

ATTACK PLAN FASE 2: 3 SKENARIO

Skenario	Kategori	Tools	Target	Deteksi yang diharapkan
1. Port dan service scanning	Reconnaissance	nmap	192.168.12.5, seluruh port	Alert scan Security Onion (ET SCAN, SYN Scan)
2. Brute-force SSH dan cek autentikasi dashboard	Exploitation / Akses	Hydra, curl	SSH 192.168.56.10 (host-only); dashboard :5000 dari Kali	Banyak login SSH gagal; dari Kali ke port 22 tidak ada log (diblok UFW)
3. Uji validasi input dashboard (SQLi/XSS)	Web/API	Burp Suite, OWASP ZAP	Dashboard Flask 192.168.12.5:5000	Deteksi jaringan Security Onion; logging aplikasi (C5) belum ada

3 kategori berbeda, tanpa skenario DoS. Hanya Target Node replika, data sintetis. Eksekusi mulai Minggu 10.

KENDALA DAN PEMBELAJARAN

KENDALA	CARA MENGATASI
Kondisi sebelum hardening sudah terlanjur berubah	Rule UFW lama ditambahkan lagi, di-scan nmap, lalu dihapus untuk bukti before/after
Hardening menutup akses: dashboard tak bisa dibuka dari host, SSH tak bisa dari Kali	Jalur dipisah: SSH via host-only, dashboard via internal network
Kali dan Ubuntu sama-sama 10.0.2.15 di NAT	Tidak bentrok: tiap VM punya jaringan NAT sendiri
Nmap melabeli port 5000 sebagai upnp	Dicatat sebagai dashboard Flask BiliCheck di bukti

TERIMA KASIH

Kelompok 12 | Keamanan Siber | Kelas A